

Gap Analysis: What Is Missing

● CRITICAL – Blocks Core Functionality Right Now

C-1 · Missing Environment Secrets (6 variables)

This is the single most impactful gap. Every feature that touches storage, email, or push is silently failing.

Variable	Effect If Missing	Where It's Used
B2_APPLICATION_KEY_ID	All PDF upload/download returns signing errors	lib/b2.ts
B2_APPLICATION_KEY	Same	lib/b2.ts
B2_BUCKET_NAME	Defaults to "edtech-notes" – still fails without valid keys	lib/b2.ts
RESEND_API_KEY	Email verification, password reset, approval emails all fail silently	lib/email.ts line 12
VAPID_PRIVATE_KEY	webPush.setVapidDetails() is skipped; push delivery returns no-op	routes/notifications.ts line 12
RECOVERY_SECRET	Emergency recovery returns HTTP 503	routes/admin.ts line 541

Action: Open the Secrets panel and add all six. For B2, you need a Backblaze B2 account → create a bucket → generate an App Key with read/write permissions.

C-2 · B2 Region Endpoint Hardcoded

lib/b2.ts line 9:

```
const B2_ENDPOINT = `https://s3.us-east-005.backblazeb2.com`;
```

If your B2 bucket is in eu-central-003 or any other region, every S3 call will fail with a 301/redirect error that the SDK doesn't follow.

Fix: Add B2_ENDPOINT as an env var and read it:

```
// lib/b2.ts - replace the hardcoded constant
```

```
const B2_ENDPOINT = process.env.B2_ENDPOINT ?? "https://s3.us-east-005.backblazeb2.com";
```

File: artifacts/api-server/src/lib/b2.ts

C-3 · Email Verification Silently Skips on Send Failure

auth.ts lines 88–93: if Resend fails during registration, the user is created but catches the error and returns 503. However, the user record **is already written to the DB** before the email call. On a retry the user gets a duplicate-email error. There's no rollback.

Fix: Wrap the insert + email send in a transaction, or at minimum delete the user row if email dispatch fails.

File: artifacts/api-server/src/routes/auth.ts ~line 75

● HIGH – Feature Gaps vs SRS v7.3

H-1 · Profile Photo URL Expiry (SRS FR-PROF-04)

B2 presigned download URLs expire in **900 seconds (15 min)**. The profile photo URL is fetched once and stored in React Query cache – after 15 minutes the `<img src>` will 403. There is no auto-refresh.

Fix: Add a `staleTime: 600_000` (10 min) on the profile query + invalidate on focus, or fetch a fresh download URL client-side when the image 404s. Alternatively, make the profile photo bucket **public** in B2 (no presigning needed for public photos).

Files: artifacts/edtech-platform/src/pages/profile.tsx, artifacts/api-server/src/routes/profile.ts

H-2 · JWT Has No Server-Side Revocation (SRS FR-SEC-02)

Logout (POST /auth/logout) currently just returns `{ success: true }` – the JWT token continues to be valid until natural expiry. If a token is stolen or an admin suspends a user, the suspended user can keep making authenticated requests until token expiry.

Fix: Maintain a token denylist (Redis, or a lightweight `revoked_tokens` DB table with TTL cleanup). Alternatively, shorten JWT expiry to 1 hour and use refresh tokens.

Files: artifacts/api-server/src/lib/auth.ts, artifacts/api-server/src/routes/auth.ts

H-3 · PWA Install Icons Missing (SRS NFR-PWA-01)

manifest.json only lists favicon.svg. Browsers require PNG icons at **192×192** and **512×512** to show the "Add to Home Screen" prompt. Android Chrome will silently skip installation without these.

// What's needed in manifest.json

```
"icons": [  
  
  {"src": "/icons/icon-192.png", "type": "image/png", "sizes": "192x192"},  
  
  {"src": "/icons/icon-512.png", "type": "image/png", "sizes": "512x512",  
   "purpose": "maskable"}  
  
]
```

Files: artifacts/edtech-platform/public/manifest.json, add PNG files to public/icons/

H-4 · Rate Limiting Gaps (SRS FR-SEC-05)

Rate limiting exists only on 5 specific routes (register, change-password, resend-verification, upload-url, profile-upload-url). The SRS calls for broader abuse prevention. **Missing rate limits on:**

- POST /api/auth/login – brute-force login attacks
- POST /api/auth/forgot-password – email flooding
- GET /api/exams/:examId – scraping
- Any admin broadcast notification endpoint

File: artifacts/api-server/src/app.ts – add loginLimiter and forgotPasswordLimiter

H-5 · Password Reset Token Is Not Single-Use Enforced

After calling POST /auth/reset-password, the token is cleared from the DB – this is correct. However, if a network error causes the client to resend the same token before the DB write completes, the token can be used twice. The reset route should clear the token atomically in the same DB transaction as the password update.

File: artifacts/api-server/src/routes/auth.ts ~line 273

🟡 MEDIUM – Quality & Completeness

M-1 · PDF Annotations Are Browser-Local Only (SRS FR-P02)

The annotation feature implemented this session stores text in localStorage. If the user clears browser data, switches devices, or uses a private window, all annotations are lost.

SRS requires server-side persistence. The notes table has no annotations column.

Fix:

1. Add annotations text column to lib/db/src/schema/notes.ts
2. Run `pnpm --filter @workspace/db run push`
3. Add GET /api/notes/:noteId/annotations and PUT /api/notes/:noteId/annotations endpoints
4. Add these to lib/api-spec/openapi.yaml → run codegen → update notes.tsx to use the generated hooks instead of localStorage

Files: lib/db/src/schema/notes.ts, artifacts/api-server/src/routes/notes.ts, lib/api-spec/openapi.yaml, artifacts/edtech-platform/src/pages/notes.tsx

M-2 · No apple-touch-icon or PWA Screenshots

iOS Safari ignores manifest.json. For proper "Add to Home Screen" on iPhones (a significant chunk of Indian competitive exam students), you

need:

```
<!-- in index.html <head> ->  
  
linkrel="apple-touch-icon"href="/icons/apple-touch-icon.png">  
  
<metaname="apple-mobile-web-app-capable"content="yes"><metaname="apple-  
mobile-web-app-status-bar-style"content="black-translucent">
```

Files: artifacts/edtech-platform/index.html, add public/icons/apple-touch-icon.png (180×180)

M-3 · Drill Mode UI Not Verified

The DB has exam_type = "drill" and the results endpoint has POST /results/:resultId/drill. But there is no dedicated drill-mode exam interface page – it appears to reuse the standard exam-interface. Drill mode (wrong-answer-only retry) should have a distinct UX per SRS Section 6.5.8.

File: artifacts/edtech-platform/src/pages/exam-interface.tsx or a new artifacts/edtech-platform/src/pages/drill-mode.tsx

M-4 · Math Rendering Scope

math-text.tsx exists but its depth needs verification – the SRS requires KaTeX for JEE/NEET chemistry/physics equations. Ensure $...$ and $...$ inline LaTeX renders correctly inside question text and solution text on the exam interface and results pages.

File: artifacts/edtech-platform/src/components/math-text.tsx, artifacts/edtech-platform/src/pages/exam-interface.tsx

M-5 · B2_ACCOUNT_ID Env Var Referenced but Unused

lib/b2.ts line 5 reads B2_ACCOUNT_ID but never passes it to the S3Client constructor. The S3-compatible B2 API uses B2_APPLICATION_KEY_ID as the access key. This is just dead code that may confuse setup.

File: artifacts/api-server/src/lib/b2.ts – remove the unused B2_ACCOUNT_ID constant

M-6 · No Sentry Error Monitoring (SRS NFR-OPS-01)

Unhandled exceptions and slow queries are invisible in production. The SRS lists Sentry as a required integration.

Add: @sentry/node to api-server, @sentry/react to frontend – gated behind SENTRY_DSN env var

Files: artifacts/api-server/src/index.ts, artifacts/edtech-platform/src/main.tsx

Part 3 – Environment Variables: Complete Required Set

Variable	Status	Required For
DATABASE_URL	✓ SET	PostgreSQL connection
SESSION_SECRET	✓ SET	JWT signing
VAPID_PUBLIC_KEY	✓ SET	Push subscription
VAPID_SUBJECT	✓ SET	VAPID identity
B2_APPLICATION_KEY_ID	✗ MISSING	All file storage

Variable	Status	Required For
B2_APPLICATION_KEY	✗ MISSING	All file storage
B2_BUCKET_NAME	✗ MISSING	All file storage
B2_ENDPOINT	✗ MISSING	B2 regional URL
RESEND_API_KEY	✗ MISSING	All transactional email
VAPID_PRIVATE_KEY	✗ MISSING	Push delivery
RECOVERY_SECRET	✗ MISSING	Emergency recovery
FROM_EMAIL	⚠ Optional	Email sender (defaults to onboarding@resend.dev)
SENTRY_DSN	⚠ Optional	Error monitoring

Part 4 – Production Readiness Roadmap

Phase 1 – Unblock Core Infrastructure (Do First)

1. Set all 6 missing secrets in Replit Secrets panel
2. Fix B2_ENDPOINT env var in lib/b2.ts
3. Test registration → email verification → login flow end-to-end
4. Test PDF upload to B2 (upload a notes PDF as a student)

Phase 2 – Security Hardening

5. Add rate limiting to POST /auth/login and POST /auth/forgot-password

1. Fix registration rollback on email-send failure (transaction)

2. Implement JWT denylist or shorten token + add refresh token

Phase 3 – PWA Completeness

8. Generate PNG icons (192, 512, apple-touch-icon) and update manifest.json + index.html
1. Verify push notifications deliver end-to-end once VAPID_PRIVATE_KEY is set

Phase 4 – Feature Completion

10. Server-side PDF annotations (DB column + API endpoints + codegen)
1. Drill mode dedicated UI
2. Verify math rendering (KaTeX) on exam interface
3. Profile photo URL refresh mechanism

Phase 5 – Production Polish

14. SMS OTP for mobile verification (Msg91 or Twilio)
1. Sentry error monitoring
2. Cloudflare CDN in front of B2 (cuts egress cost, speeds delivery)
3. Remove unused B2_ACCOUNT_ID constan